# V2 — Améliorations hors cours : ce qui a été ajouté après la soutenance

> Projet E21 « Des agents IA pour analyser les risques » — M2 Cybersécurité, Sup de Vinci Rennes. Ce document sépare **la production d'école** (travail de groupe de Melvin Raimbault, Lucas Huard, Jérémy Lessa et David Amaro Monteiro, jusqu'au 24 septembre 2026) des **améliorations personnelles** de Melvin Raimbault faites ensuite, hors cours.

## 1. Où passe la frontière

| | Production école (V1) | Améliorations hors cours (V2) |
|---|---|---|
| **Période** | 23 → 24 septembre 2026 | 4 → 12 octobre 2026 (en cours) |
| **Référence** | tag Git `ecole-2026-09-24` (commit `b7f3155`, 24/09 à 13h34, juste après le dépôt du PPT de soutenance) | branche `corrections/chaine-ollama-pilote` |
| **Commits** | 40 | 144 (dont 118 hors fusions), au commit `cc1b2c0` du 12/10 à 18h44 |
| **Python (hors tests)** | 640 lignes (le script du PPT) : le système était un *POC piloté par consignes*, sans code applicatif | ≈ 22 500 lignes + ≈ 10 000 lignes de tests (35 fichiers) |
| **Écart** | — | 184 fichiers modifiés, + 35 000 lignes |
| **Nature** | système d'agents opencode, cas ShoPix, 14 risques validés, dossier, soutenance | application complète : ingestion, site web, pilote déterministe, dossier de connaissance, validation, exports, mise à jour |

Le tag est **immuable** : il fige l'état école. Tout ce qui est décrit ci-dessous est postérieur.

## 2. Les limites annoncées en V1 et ce qu'est devenue chacune

Le plan de soutenance V1 (`PLAN-45MIN.md`, partie « Ce que l'outil ne fait pas ») listait des limites et une feuille de route. La V2 répond à presque chacune d'elles.

| Limite ou promesse de la V1 | État en V2 | Où |
|---|---|---|
| Pas de lecture automatique des documents (PDF, Excel, Word, images) | **Fait** : PDF texte et scannés (OCR FR/EN), XLSX/CSV, DOCX, PPTX, images, ZIP ; tout contenu est une *donnée* | `tools/ingest/` (#25) |
| Pas d'interface, uniquement l'éditeur opencode | **Fait** : site Streamlit en 4 étapes (documents, lancer, résultats, validation), Studio d'édition des agents | `web/`, `tools/studio/` (#26) |
| Rapports non exportables | **Fait** : rapport exécutif PDF/HTML/MD/JSON, puis dossier d'analyse complet avec liens (HTML, PDF, ZIP) | `tools/export/` (#27) |

| Limite ou promesse de la V1 | État en V2 | Où |
|---|---|---|
| Modèle cloud uniquement, local « en roadmap » | **Fait** : chaîne 100 % locale avec Ollama sur une carte graphique 12 Go, un modèle par rôle | `web/chaine.py`, `web/reglages.py` |
| EBIOS RM seulement « documenté » | **Fait** : EBIOS RM (ateliers A1–A5), PASTA (7 étapes), LINDDUN (7 fiches), validateur STRIDE | `tools/methodes/` (#28) |
| Pas de volet détection / inventaire | **Fait** (local, opt-in) : inventaire anonymisé, 12 règles MITRE ATT&CK | `tools/reseau/` (#29) |
| Analyse manuelle de référence à produire (#17) | **Fait le 15/10** sur SanteTech : 30 risques classiques comparés aux 135 des agents (16 couverts, 7 partiels, 7 non couverts), **à relire et valider par l'analyste**. Le brouillon ShopPix du 04/10 (12 menaces, 9 retrouvées) a été rédigé avec l'assistant et n'est pas retenu comme analyse manuelle | `soutenance/analyse-manuelle/ANALYSE-MANUELLE-SANTETECH.xlsx` ; `analyses/…/reference-manuelle.md` |
| Test d'injection réel non exécuté (T-11) | **Fait** le 04/10 : exécution archivée, 11 contrôles, aucune consigne exécutée (sans appel du modèle) ; **rejoué le 15/10 avec le modèle en direct** sur la chaîne complète : 116 risques, aucune consigne exécutée | `soutenance/tests/injection/resultats/` ; `soutenance/tests/injection/resultats-live-2026-10-15/` |
| Pas de CI | **Fait** : suite de référence rejouée sur chaque push/PR | `.github/workflows/suite.yml` |
| Pas de supervision continue | **Partiel** : la mise à jour incrémentale suit les changements de documents ; pas de supervision temps réel | `web/miseajour.py` |
| Pas de scan réseau actif | **Inchangé volontairement** : jamais de scan externe ni automatique | — |
| Pas d'analyse de code applicatif | **Inchangé** | — |
| Aucune décision automatique | **Inchangé et renforcé** : `valide_par` reste humain, la décision est enregistrée avec l'empreinte du contenu décidé | `web/validations.py`, `web/registre.py` |

# 3. Chronologie par phase

## Phase A — 4 → 8 octobre : outiller, ouvrir, déployer

La semaine d'amélioration planifiée (issues #25 à #31) est exécutée le 4 octobre, puis le projet est mis en service sur un serveur.

| Date | Livré | Issue / commit |
|---|---|---|
| 04/10 | **Ingestion documentaire** : sept formats, ZIP protégé (zip-slip), tout intrant traité comme donnée | #25 · `11ab26f` |
| 04/10 | **Préparation** : brouillon de `00-description.md`, questions automatiques sur les trous détectés | #31 · `f1bbab6` |
| 04/10 | **Interface web** locale + **exports** PDF/HTML/MD/JSON | #26, #27 · `bc0d82c` |

| Date | Livré | Issue / commit |
|---|---|---|
| 04/10 | **Méthodes opérationnelles** : EBIOS RM, PASTA, LINDDUN, STRIDE | #28 · `54bfaf8` |
| 04/10 | **Détection amont** + inventaire local anonymisé (12 règles ATT&CK) | #29 · `91f10f8` |
| 04/10 | **Consolidation** : test d'injection réel archivé (T-11), brouillon d'analyse de référence ShoPix (rédigé avec l'assistant), discours honnête, arbitrage budgétaire | #30 · `62d4576` |
| 04/10 | **CI** GitHub Actions, revue de cohérence, clôture de la semaine (19 tests PASS) | `5abe860`, `6b6082d`, `411e194` |
| 04/10 | Lancement de la chaîne **depuis le site** (commande fixe, aucune donnée utilisateur dans la commande), test « aucune donnée privée dans Git » (T-19) | `050d3a4` |
| 04/10 | **Studio E21** : base SQLite source de vérité des agents et skills, édition web, état Ollama (T-20) | `4e73fcc` |
| 04–05/10 | **Docker** (image Debian, OCR, PDF), script de mise à jour du serveur, opencode dans l'image | `3fc4fd2`, `1a7d234`, `5554def` |
| 05/10 | Dépôt de documents en un clic (fichiers multiples, dossier ZIP), suppression d'un intrant avec signalement des artefacts qui le citent | #55 → #60 |
| 05/10 | **Réglages modèles** : deux profils (opencode / Ollama), modèle recommandé par agent pour une carte 12 Go | #59 → #66 |
| 05/10 | Corrections de permissions (agents non enregistrés, règle `edit` inversée, shell décidé au niveau de l'outil) : la chaîne devient exécutable depuis le site | #67 → #72 |
| 06–08/10 | La chaîne survit au rechargement de la page ; ZIP OOXML réellement analysés ; sonde de contexte et détection des fins sans livrable ; ordre strict des étapes 1 à 7 | #75 → #80 |

## Phase B — 8 → 12 octobre : fiabiliser, prouver, valider, mettre à jour

Le test réel de la chaîne sur un gros cas (22 documents) fait apparaître que les petits modèles locaux ne tiennent pas seuls une analyse longue. La phase B déplace donc la fiabilité **du modèle vers le code**.

| Date | Livré | Commit |
|---|---|---|
| 09/10 | **Pilote déterministe** : l'ordre des 7 étapes, les reprises et la vérification des livrables sont du code ; routage d'un modèle par rôle ; contrôle bloquant ; relecture finale | `430977d`, `c719ace`, `b140dad` |
| 09/10 | Parcours guidé en 4 étapes, projet unique, budget de pièces jointes de 40 Ko avec signalement des omis | `5d323d7`, `62b2262` |
| 09–10/10 | **Dossier de connaissance** : faits à extrait exact vérifié par le code, relations typées, index hybride, contradictions croisées, couverture connu / partiel / inconnu, passages d'origine, deux vérificateurs | `47ca02e`, `939fe47` |
| 10/10 | **Étape 0** : rapports de contrôle numérotés par version, validation humaine expliquée (pourquoi, quoi vérifier), contrôle direct par Ollama sans outil ni résumé | `31e246a`, `3e104f3` |
| 10/10 | **Ingestion incrémentale**, dossier de preuves par étape avec citations `[E12]` vérifiées, **propagation ciblée** des décisions, recherche externe séparée des documents | `45b01aa`, `55f4eb3`, `930890c`, `f54ad05` |

| Date | Livré | Commit |
|---|---|---|
| 10/10 | **Boîte de validation unique** (risques, étapes, lignes, contradictions, questions) ; modes *Reprendre* / *Tout refaire* | `80f955a`, `2f33d63` |
| 10/10 | Dossier de preuves v2 : passages d'origine avec en-têtes de colonnes, écarts chiffrés d'abord, décisions de l'analyste prioritaires | `008fdbc`, `0620877` |
| 11/10 | **Production par lots** assemblée par le code ; contrôles de cohérence ; carte d'identité des documents (type, fiabilité, date) ; sources et CVE inventées retirées par le code | `d8bcb57` → `c6e2403` |
| 11/10 | **Étapes 6 et 7 établies par le code** (registre de 151 lignes au lieu de 9, 2 minutes au lieu de 30) ; page de validation regroupée par niveau | `ae81cc4`, `d49b9a7` |
| 12/10 | Page de validation : cartes sous leur tableau, contradictions et questions en premier, enregistrement par bloc — **validée par l'analyste** | `68dd595`, `402cff3` |
| 12/10 | **Mise à jour incrémentale** : identifiants de preuve stables, calcul des changements, plan visible avant d'appliquer, application ligne par ligne contrôlée, décisions « à confirmer » | `14da407` → `0a5f0bc` |
| 12/10 | **Export du dossier complet** : HTML avec liens document → preuve → actif → risque → décision, PDF, ZIP | `097bc57` |
| 12/10 | **Réparation des schémas Mermaid** par le code (3 sur 13 étaient invalides), affichés dans le site et l'export | `5b89e94`, `ad734e7` |

## 4. Ce que la V2 change dans la démarche

1. **Du modèle au code.** La V1 confiait la fiabilité aux consignes des agents. La V2 laisse au modèle ce qu'il fait bien

(extraire, rédiger, juger un point) et confie au code ce qui doit être exact : l'ordre des étapes, l'assemblage des tableaux, le calcul du niveau de risque, les identifiants, la suppression des sources inventées, le registre, la synthèse chiffrée.

1. **Chaque affirmation renvoie à une preuve.** Un fait écrit dans un livrable cite `[E12]`, qui renvoie à l'extrait exact d'un

document. Le code vérifie que l'extrait existe vraiment dans le document.

1. **L'humain décide, avec le contexte.** La page de validation montre, pour chaque point, la preuve, le document, la valeur

proposée et les écarts entre documents. Sa décision est conservée quand l'analyse est mise à jour.

1. **On n'efface rien, on n'écrase rien.** Un relancement archive l'analyse précédente ; une mise à jour laisse les lignes

inchangées identiques à l'octet près ; un retrait est seulement proposé.

1. **L'honnêteté est mesurée.** Chaque limite connue est écrite avec son chiffre (voir le dossier écrit V2, partie 9).

## 5. Pièces de référence

| Besoin | Fichier |
|---|---|
| Dossier écrit complet de la V2 | `DOSSIER-ECRIT-V2.md` (+ PDF) |
| Explications du projet et réponses aux questions du jury | `EXPLICATIONS-DU-PROJET.md` |
| Soutenance V2 | `Soutenance_E21_V2.pptx`, `PLAN-45MIN-V2.md` |

| Besoin | Fichier |
|---|---|
| Livrables école, tels qu'ils étaient | dossier `V1-ecole/` et tag `ecole-2026-09-24` |
| Documentation technique détaillée | `documentation/technique/07` à `10` dans le dépôt |